

NEXOVA SYSTEMS

Linux Infrastructure Standard Operating Procedures

Document ID: NSY-INFRA-SOP-001

Version: 3.2

Classification: Internal — Infrastructure Team

Last Reviewed: 2025-04-01

Owner: Platform Engineering

Table of Contents

1.	New Server Provisioning	3
2.	Package Management Policy	4
3.	User Account Management	5
4.	SSH Hardening Requirements	6
5.	Firewall Configuration Standards	7
6.	Cron Job Governance	8
7.	Docker & Container Operations	9
8.	Backup & Disaster Recovery	10
9.	Incident Response	11
10.	Contacts & Escalation	12

1. New Server Provisioning

All new Linux servers must be provisioned following this checklist before being added to any production environment. Deviations require written approval from the Platform Engineering lead.

1.1 Minimum Hardware Requirements

Tier	vCPU	RAM	Root Disk	Use Case
T1 — Edge	2	4 GB	40 GB SSD	Lightweight services, proxies
T2 — Standard	4	16 GB	100 GB SSD	Web apps, APIs
T3 — Compute	8	32 GB	200 GB SSD	Databases, ML workloads
T4 — Storage	4	16 GB	2 TB HDD	Backup targets, object storage

1.2 Post-Provisioning Checklist

- Set hostname to the format: **<env>-<role>-<nn>.nexova.internal** (e.g. prod-web-01.nexova.internal)
- Run **apt-get update && apt-get upgrade -y** immediately after first boot
- Install the Nexova monitoring agent: **apt-get install nexova-agent**
- Configure NTP to point to **ntp.nexova.internal**
- Add the server to the CMDB within 24 hours via the ServiceNow portal
- Enable and start the firewall (see Section 5)
- Verify SSH key-based auth is working before disabling password auth (see Section 4)

NOTE: All provisioning steps must be recorded in the server's CMDB ticket. Undocumented servers will be flagged for decommission after 7 days.

2. Package Management Policy

Nexova uses Ubuntu LTS as the standard server OS. Only approved package sources may be used. Third-party PPAs require security team sign-off.

2.1 Approved Package Sources

- Ubuntu official repositories: **main**, **restricted**, **universe**
- Nexova internal apt mirror: **apt.nexova.internal** (preferred for production)
- Docker CE official repository (for container hosts only)

2.2 Patching Schedule

Environment	Security Patches	Full Upgrades	Approval Required
Production	Within 72 hours	Monthly — 1st Sunday 02:00 UTC	Yes — Change board
Staging	Within 1 week	Weekly — Sunday 03:00 UTC	No
Development	Within 2 weeks	On demand	No

2.3 Prohibited Actions

WARNING: The following are prohibited without explicit security team approval and a Change Request ticket:

- Installing packages from untrusted or unreviewed PPAs
- Pinning packages to versions older than the current Ubuntu LTS default
- Holding back security updates for more than 72 hours on production systems
- Installing development tools (gcc, make, build-essential) on production servers

3. User Account Management

All user accounts on Nexova infrastructure must be traceable to a named employee or service. Shared or anonymous accounts are prohibited.

3.1 Account Creation

- New accounts are requested via the IT helpdesk portal (helpdesk.nexova.internal)
- Usernames follow the format: **firstlast** for humans, **svc-~~appname~~** for service accounts
- All human accounts must be added to the **nexova-users** group
- Sudo access requires manager approval and must be documented in the CMDB

3.2 Standard Group Memberships

Group	Purpose	Who gets it
nexova-users	Base group for all human accounts	All employees
nexova-ops	Read access to logs and service status	Ops team
nexova-deploy	Deployment automation permissions	DevOps, CI/CD service accounts
docker	Docker socket access	DevOps, container-role hosts only
sudo	Full sudo privileges	Senior engineers + approved accounts only

3.3 Account Offboarding

- Accounts must be disabled within **4 hours** of an employee's last day notification
- Home directories are archived to **/archive/offboarded/** and retained for 90 days
- Service accounts owned by a departing employee must be re-owned before the account is disabled

WARNING: Failure to disable accounts within the 4-hour SLA is a SOC 2 compliance violation and must be reported to the security team.

4. SSH Hardening Requirements

All Nexova servers must comply with the following SSH configuration. The Platform Engineering team audits `sshd_config` compliance monthly using Ansible.

4.1 Required `sshd_config` Settings

```
PermitRootLogin no
PasswordAuthentication no
PubkeyAuthentication yes
MaxAuthTries 3
LoginGraceTime 30
AllowTcpForwarding no
X11Forwarding no
ClientAliveInterval 300
ClientAliveCountMax 2
Port 2222
```

NOTE: Nexova uses non-standard port 2222 for SSH on all servers. Firewall rules allow port 2222 only from 10.10.0.0/16 (VPN range).

4.2 SSH Key Standards

- Minimum key type: **Ed25519** (preferred) or RSA-4096
- RSA keys below 4096 bits are not accepted
- Key passphrases are mandatory for all human accounts
- Service account keys are stored in Vault at **vault.nexova.internal**
- Keys must be rotated every **12 months** or immediately upon suspected compromise

4.3 Bastion Host Policy

Direct SSH to production servers is not permitted. All access must route through the bastion host:

```
ssh -J bastion.nexova.internal <username>@<target-server>
```

- Bastion sessions are logged and retained for 1 year
- Session recording is enabled via **script** on the bastion; recordings stored in S3

5. Firewall Configuration Standards

Nexova uses **ufw** on all servers. The default policy is deny-inbound, allow-outbound. All rule changes on production require a Change Request ticket.

5.1 Default Ruleset — All Servers

Port / Service	Protocol	Direction	Source	Purpose
2222	TCP	IN	10.10.0.0/16	SSH (VPN only)
80	TCP	IN	0.0.0.0/0	HTTP (redirect to HTTPS)
443	TCP	IN	0.0.0.0/0	HTTPS
9100	TCP	IN	10.10.5.0/24	Prometheus node exporter
ALL	ALL	OUT	0.0.0.0/0	Outbound (permitted)

5.2 Role-Specific Additional Rules

- **Database servers:** allow TCP 5432 (PostgreSQL) from 10.10.2.0/24 (app-server subnet)
- **Web servers:** no additional rules beyond the default set
- **Container hosts:** allow TCP 2375 from 10.10.5.0/24 (monitoring subnet) — never expose to internet
- **Backup targets:** allow TCP 873 (rsync) from 10.10.4.0/24 (backup subnet)

WARNING: Never run 'ufw disable' on a production server without a maintenance window and approval. Use 'ufw status' to verify rules before making changes.

6. Cron Job Governance

All cron jobs running on Nexova infrastructure must be registered in the CMDB. Unregistered cron jobs found during audits will be removed.

6.1 Approved Recurring Jobs

Schedule	Command	User	Host	Purpose
0 2 * * *	/usr/local/bin/nexova-backup.sh	root	All servers	Nightly backup
0 3 * * 0	apt-get upgrade -y --with-new-pkgs	root	Non-prod	Weekly patching
* /5 * * * *	/usr/local/bin/health-check.sh	nexova	All servers	Health ping
0 1 * * *	/usr/local/bin/log-rotate.sh	root	Web servers	Log rotation
30 23 * * *	/usr/local/bin/db-vacuum.sh	postgres	DB servers	Postgres vacuum

6.2 Adding New Cron Jobs

- Submit a CMDB ticket with: schedule, command, user, host, and business justification
- Output must be redirected — silent failures are not acceptable: **cmd >> /var/log/nexova/<job>.log 2>&1**
- Jobs running as root require Platform Engineering approval
- Test in staging for at least 2 cycles before promoting to production

NOTE: Use @reboot sparingly. Jobs that must run on reboot should prefer systemd units for better logging and dependency management.

7. Docker & Container Operations

Nexova runs containerised workloads on dedicated container hosts. Running Docker on non-designated hosts requires Platform Engineering approval.

7.1 Image Standards

- All production images must be built from Nexova-approved base images stored in **registry.nexova.internal**
- Images must be scanned with **Trivy** before promotion to production; no CRITICAL CVEs permitted
- Image tags must be immutable SHAs or versioned releases — **latest** tag is banned in production
- Images are automatically purged from the registry after 90 days of no pulls

7.2 Container Runtime Requirements

- Containers must not run as root — use **USER** directive in Dockerfile
- Memory limits are mandatory: set via **--memory** or in the compose file
- Containers must log to stdout/stderr only — no log files inside the container
- Sensitive values must be injected via Docker secrets or environment variables from Vault — never baked into images

7.3 Compose File Location and Naming

```
/opt/nexova/<service-name>/  
  docker-compose.yml  
  .env                # symlink to Vault-managed env file  
  data/               # bind-mount target (non-container-managed volumes)
```

WARNING: Do not run 'docker rm' or 'docker prune' on production hosts without verifying no stateful volumes will be lost. Always run 'docker volume ls' first.

8. Backup & Disaster Recovery

Nexova follows a 3-2-1 backup strategy: 3 copies, 2 different media types, 1 offsite.

8.1 Backup Schedule & Retention

Data Type	Frequency	Local Retention	Offsite (S3)	Tool
Full server	Weekly	2 weeks	3 months	tar + gpg
Database (Postgres)	Daily	7 days	1 year	pg_dump + gzip
App config files	Daily	30 days	1 year	rsync
Docker volumes	Daily	7 days	3 months	tar
Logs	Daily	30 days	1 year	logrotate + rsync

8.2 Backup Storage Locations

- Local: `/opt/nexova/backups/` on each server
- NAS: `\\\\nas01.nexova.internal\\backups\\<hostname>` (mounted at `/mnt/nas-backup`)
- Offsite: `s3://nexova-backups-prod/<hostname>/` — encrypted with AES-256

8.3 Recovery Time & Point Objectives

Service Tier	RTO	RPO	Priority
Tier 1 — Critical (auth, payments)	1 hour	15 min	P1
Tier 2 — Core (APIs, databases)	4 hours	1 hour	P2
Tier 3 — Standard (web, workers)	8 hours	4 hours	P3
Tier 4 — Non-critical (dev, logs)	24 hours	24 hours	P4

WARNING: Backup restore tests are mandatory quarterly. Results must be logged in the DR test register (Confluence: Platform Engineering > DR Tests).

9. Incident Response

Nexova follows a 5-phase incident response process: Detect → Triage → Contain → Remediate → Post-mortem.

9.1 Severity Definitions

Severity	Definition	Response SLA
P1	Full outage of a Tier 1 service or data breach	15 min acknowledgement, all-hands
P2	Degraded Tier 1 or full outage of Tier 2 service	30 min acknowledgement
P3	Non-critical service down or performance degradation	2 hour acknowledgement
P4	Minor issue, no customer impact	Next business day

9.2 On-Call Runbook

- P1/P2: Page on-call via PagerDuty immediately; open a war-room Slack channel **#incident-<date>**
- Preserve evidence before remediating: **journalctl --since, ps aux, netstat -tulpn**
- Do not reboot servers to resolve incidents without first capturing logs
- Post-mortem must be filed within **48 hours** of incident resolution (Confluence template: Incident Post-Mortem)

10. Contacts & Escalation

Role	Name	Slack	PagerDuty
Platform Eng Lead	Sarah Okonkwo	@sokonkwo	nexova-platform
Security Lead	Dmitri Volkov	@dvolkov	nexova-security
On-Call (rotation)	See PagerDuty	#ops-oncall	nexova-oncall
IT Helpdesk	helpdesk team	#it-helpdesk	N/A
CTO (P1 escalation)	Amara Nwosu	@anwosu	nexova-cto-p1

This document is reviewed quarterly. Raise suggested changes via a pull request to github.com/nexova-internal/runbooks or open a ticket in the IT helpdesk portal. Document owner: Platform Engineering. Next review date: 2025-07-01.